

MANUEL DEVICE

Manuel d'utilisation — IRON MAN AI : Audit de périphérique Android

Le module **Périphérique** de IRON MAN AI audite la **posture de sécurité** d'un appareil Android (téléphone, tablette) que vous possédez : type de verrou d'écran, chiffrement du stockage, débogage USB, adb réseau, bootloader/OEM unlock, SELinux, fausses positions, services d'accessibilité, sources inconnues. Il produit une **note de posture /100** et des recommandations de durcissement.

Toutes les commandes sont **en lecture seule** (getprop, settings get, dumpsys, getenforce) : **aucune modification de l'appareil**.

 **Sécurité et éthique.** Cet audit teste la *résistance* de votre

appareil aux techniques de déverrouillage et de compromission. Il ne

permet **pas** de déverrouiller un appareil que vous ne possédez pas.

Le flag `--authorized` est obligatoire : votre matériel ou un appareil

pour lequel vous avez une autorisation écrite (audit interne, test

mandaté). Tenter de contourner le verrou d'un appareil sans

autorisation est illégal.

1. Prérequis

- **adb** : `sudo apt-get install -y adb` (OU `android-tools-adb`).

- Un appareil Android **branché en USB** avec **débogage USB activé** : 1. Paramètres → À propos → tapez 7 fois sur « Numéro de build » (active les options développeur) ; 2. Paramètres → Options développeur → activez **Débogage USB** ; 3. À la première connexion, acceptez l'invite « Autoriser le débogage USB ? » sur l'écran de l'appareil (cochez « Toujours autoriser »).
- **Important** : activer le débogage USB nécessite l'accès à l'écran de l'appareil — c'est la garantie que c'est le vôtre.

Vérifiez les outils :

```
cd /chemin/codescan
python mobile_scan.py --check          # vérifie les 3 modules (WiFi, Android, adb)
python mobile_scan.py --device --check # vérifie uniquement adb
```

2. Première analyse : un appareil en une commande

```
python mobile_scan.py --device --authorized
```

- Si un **seul** appareil est connecté, il est détecté automatiquement.
- Si **plusieurs** sont branchés, précisez le serial (`adb devices` pour le lister) :

```
python mobile_scan.py --device --serial ZY12345678 --authorized
```

Sortie console : modèle, version Android, correctif de sécurité, verrou, chiffrement, SELinux, puis la liste des contrôles avec leur verdict (● critique, ● avertissement, ● ok) et la **note de posture /100**.

3. Rapport complet (JSON + HTML)

```
python mobile_scan.py --device --authorized -o /tmp/rapport_appareil
```

Produit `rapport_appareil.json` et `rapport_appareil.html` (autonome, lisible dans un navigateur) : informations de l'appareil, note de posture, chaque contrôle avec sa recommandation.

4. Les contrôles réalisés

Contrôle	Risque si mauvais	Sévérité
Verrou d'écran (aucun)	accès physique = accès aux données	 critique
Chiffrement du stockage (non chiffré)	données lisibles sans clé	 critique
adb réseau (adb tcpip)	écoute réseau sans câble	 critique
SELinux (Permissive)	isolation affaiblie	 critique
Fausse positions (mock location)	GPS falsifiable	 critique
Débogage USB activé	commandes depuis un PC (nécessaire pour l'audit)	
Bootloader déverrouillé / OEM unlock	firmware modifié possible	
Build userdebug/eng	accès root possible	
Services d'accessibilité actifs	lecture écran/frappes	
Sources inconnues / vérification off	sideload malveillant	
Vérification des applications (Play Protect) off	apps malveillantes	

La note part de 100 : **-25 par contrôle critique, -10 par avertissement**

(bornée à 0).

5. Interpréter le résultat et durcir l'appareil

- **Score ≥ 80** : bonne posture. Pensez à **désactiver le débogage USB** après l'audit (c'est le seul avertissement habituel).
- **Score 40-79** : des points faibles réels (ex. pas de verrou, sources inconnues) — appliquez les recommandations de chaque contrôle.
- **Score < 40** : appareil très exposé (adb réseau, SELinux permissif, stockage non chiffré...) — durcissez avant usage quotidien.

Le rapport HTML détaille pour chaque contrôle la **recommandation**

exacte (paramètres à modifier, commandes fastboot, etc.).

6. Cas d'usage efficaces

1. **Avant de vendre / donner un appareil** : vérifiez qu'il n'y a pas d'accès résiduel (verrou, FRP, adb réseau) et faites une réinitialisation propre.
1. **Parc d'entreprise** : auditez chaque appareil fourni aux employés et imposez un score minimum (ex. ≥ 80) avant déploiement.
1. **Après une réparation** (écran changé, ROM réinstallée) : confirmez que le bootloader est re-verrouillé (état green) et SELinux Enforcing.
1. **Appareil d'occasion acheté** : auditez-le avant d'y mettre vos données — un bootloader déverrouillé ou un adb réseau actif est un signal d'alerte.

7. Dépannage

Problème	Cause probable	Solution
« Aucun appareil connecté »	débogage USB désactivé ou invite non acceptée	Activez le débogage USB et acceptez l'invite sur l'appareil
« Plusieurs appareils connectés »	2+ appareils branchés	<code>adb devices</code> , puis <code>--serial <serial></code>
« adb introuvable »	outil absent	<code>sudo apt-get install -y adb</code>
Verrou « inconnu »	build exotique / ROM modifiée	Vérifiez manuellement : <code>adb shell dumpsys lock_settings</code>
Résultats identiques à chaque fois	cache adb	<code>adb kill-server && adb start-server</code>

8. Limites (honnêteté technique)

- L'audit lit l'état **actuel** de l'appareil : il ne détecte pas les malwares déjà installés, ni ne « déverrouille » quoi que ce soit.
- Le type de verrou est lu via `dumpsys` : sur certaines ROM (MIUI, OneUI...), la valeur peut être « inconnu » — le contrôle reste utile via les autres indicateurs.

- Il ne remplace pas une analyse de sécurité approfondie (le module `--android` complète pour les applications, le module `--wifi` pour le réseau).
-

Cadre d'utilisation : appareils que vous possédez ou êtes autorisé à tester. `--authorized` est obligatoire.

Généré par CodeScan — manuel imprimable.